

Exército Brasileiro
Comando de Comunicações e Guerra Eletrônica do Exército



Escola de Comunicações
(Escola Coronel Hygino Corsetti)



Ethical Hacker



Networking
Academy



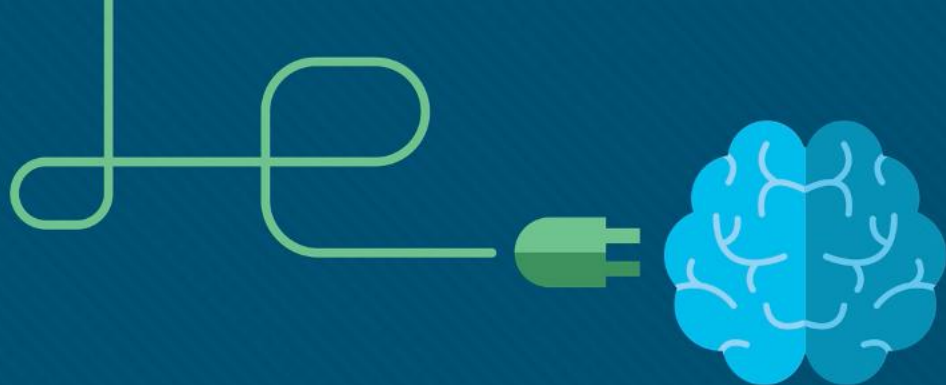
Programa
CiberEducação
Cisco Brasil



>_ WHOAMI

- Formação Acadêmica:
 - Mestrado em Engenharia Elétrica (Unb, 2026) – Áreas: Segurança Cibernética; Autenticação segura, certificados digitais, HPC.
 - Pós-graduação: Segurança da Informação (2022); Engenharia de Redes e Telecomunicações (2021).
 - Nível Superior: Análise e Desenvolvimento de Sistemas (2019).
- Formação Técnica e Certificações:
 - Ethical Hacker (Cisco netacademy)
 - Cyber Threat Management (Cisco netacademy)
 - CCNA Security
 - Curso de Guerra Cibernética (CIGE)
 - Estágio de Proteção Cibernética (EsCom)
- Atuação em Pesquisa:
 - Pesquisador DTI BR - Programa BLIS (2026-Atual): IA, Engenharia de prompts, RAG, segurança de LLM, Sistemas multiagentes.
 - Pesquisador da Escola Superior de Defesa (ESD): Geopolítica e computação de alta performance falando sobre soberania digital; e Estudo independente de criptografia PQC (Pós-Quântica).





Módulo 3: Coleta de informações e varredura de vulnerabilidades

Hacker Ético



Objetivos do Módulo

Título do módulo: Coleta de informações e varredura de vulnerabilidades

Objetivo do módulo: Execute atividades de coleta de informações e de varredura de vulnerabilidade.

Título do tópico	Objetivo do tópico
Executando reconhecimento passivo	Execute atividades de reconhecimento passivo.
Executando reconhecimento ativo	Realizar atividades de reconhecimento ativo.
Compreendendo a arte de conduzir verificações de vulnerabilidade	Execute verificações de vulnerabilidade.
Compreendendo como analisar resultados de verificação de vulnerabilidade	Analise os resultados dos exercícios de reconhecimento.

3.1 Realizando Reconhecimento Passivo

Visão geral

- O reconhecimento é sempre o passo inicial de um ataque cibernético. (IMPORTANTE!!!)
- O termo **reconhecimento** é amplamente usado no mundo militar para descrever a reunião de informações sobre o inimigo, como informações sobre a localização, capacidades e movimentos do inimigo.
- Esse tipo de informação é necessário para realizar um ataque com êxito.
- O reconhecimento em um teste de penetração normalmente consiste em varredura e enumeração.
- Mas como é o reconhecimento do ponto de vista do atacante?

Reconhecimento Ativo vs. Reconhecimento Passivo

- **O reconhecimento ativo** é um método de coleta de informações em que as ferramentas usadas enviam sondas para a rede ou sistemas de destino, a fim de obter respostas que são então usadas para determinar a postura da rede ou do sistema.
 - Estas sondas podem usar vários protocolos e vários níveis de agressividade, normalmente com base no que está sendo analisado e quando.
- **O reconhecimento passivo** é um método de coleta de informações em que as ferramentas não interagem diretamente com o dispositivo de destino ou a rede.
 - Há vários métodos de reconhecimento passivo.
 - Algumas envolvem o uso de bancos de dados de terceiros para reunir informações.
 - Outros também usam ferramentas de tal forma que não serão detectadas pelo alvo.
 - Essas ferramentas funcionam simplesmente ouvindo o tráfego na rede e usando inteligência para deduzir informações sobre a comunicação do dispositivo na rede.

Reconhecimento Ativo vs. Reconhecimento Passivo(Cont.)

- Ferramentas e métodos comuns de reconhecimento ativo incluem os seguintes:
 - Enumeração do host
 - Enumeração de rede
 - Enumeração de usuário
 - Enumeração de grupo
 - Enumeração de compartilhamento de rede
 - enumeração de páginas da Web
 - Enumeração de aplicativos
 - Enumeração de serviços
- Ferramentas e métodos de reconhecimento passivo comuns incluem o seguinte:
 - Enumeração de domínio
 - Inspeção de pacotes
 - Inteligência de fonte aberta (OSINT)
 - Recon-ng
 - Intercepção

Buscas DNS

- Suponha, por exemplo, que um agressor tenha um alvo, h4cker.org, na mira.
- h4cker.org tem presença na Internet, como a maioria das empresas faz.
- Este site está hospedado em www.h4cker.org.
- Assim como um ladrão de casas precisaria determinar quais pontos de entrada e saída existem em uma casa antes que ele pudesse cometer um roubo, um agressor cibernético precisa determinar quais das portas e protocolos do alvo estão expostos à Internet.
- Um ladrão pode dar uma volta pelo lado de fora da casa, procurando portas e janelas, e então possivelmente dar uma olhada nas fechaduras nas portas para determinar suas fraquezas.
- Da mesma forma, um agressor cibernético realizaria tarefas como varredura e enumerar.
- Normalmente, um agressor começaria com uma pequena quantidade de informações e reuniria mais informações enquanto fazia varredura, eventualmente passando para diferentes tipos de varredura e reunindo informações adicionais.

Buscas DNS (Cont.)

- Por exemplo, o atacante que tenha como alvo h4cker.org pode começar usando **consultas DNS** para determinar o(s) endereço(s) IP usado(s) pelo site h4cker.org e qualquer outro subdomínio que possa estar em uso.
- Digamos que essas consultas revelem que o h4cker.org está usando os endereços IP 185.199.108.153 para www.h4cker.org, 185.199.110.153 para mail.h4cker.org e 185.199.110.153 para portal.h4cker.org.
- O exemplo mostra a ferramenta DNSRecon no Kali Linux sendo usada para consultar os registros DNS de h4cker.org

```
--[omar@webexploit]--[~]
|--- $ dnsrecon -d h4cker.org
[*] Performing General Enumeration of Domain: h4cker.org
/usr/share/dnsrecon/./dnsrecon.py:816: DeprecationWarning: please use
dns.resolver.Resolver.resolve() instead
  answer = res._res.query(domain, 'DNSKEY')
[*] DNSSEC is configured for h4cker.org
[*] DNSKEYS:
[*] NSEC3 ZSK RSASHA256 030100019ed0af43a7cd09d07e1646d2 b4036075e9187c4c563519155f888b60
8fdffe9c6d8a0a01522f78d25d257772 0a8e97d1350e694b272ec63af9708609 b3721e6b53a2d7aa8839585714800319
dd98f97b39d8768f7e975a449c001ce9 55189ea83f30a4fe6b4dff7b3dd15f89 1cef3a8d84968a980bde65c0b1309d5b 825a0f23
[*] NSEC3 KSK RSASHA256 030100018403e0971df0dc1770f3b96a ca57eb68d03a84b4a712cadda60567fe
a264f0e5d7ec4c8e0187300f0933f419 d22a17548c3a046636666300c06711f0 761200245149a220b79918b3f38a9a6e
8228425cb39b6466adba9f6f7fe28d76 c1bcf44e19f035f658eef65cb30638f 7aa15d7706cc572c863d65619bd48f77
425ea0844716709b9923117ade41d414 c94f8e581db9274cf1c8bb41fbbd7838 24978c0f9b7125b9ce3e8abe442a6bc7
4bf519790a18a27916c946f503c02b08 0a8550bc5b9b147d581a3f5f763df377 9e1d655c51c2e06aa2062d1f08f34abc
37947ac48403dc0da9af846c7a4caee 7567bb8fd6f25b1a179e6fd6faf35be9 09488cb9
[*] SOA ns-cloud-c1.googledomains.com 216.239.32.108
[*] NS ns-cloud-c1.googledomains.com 216.239.32.108
[*] NS ns-cloud-c1.googledomains.com 2001:4860:4802:32::6c
[*] NS ns-cloud-c2.googledomains.com 216.239.34.108
[*] NS ns-cloud-c2.googledomains.com 2001:4860:4802:34::6c
[*] NS ns-cloud-c3.googledomains.com 216.239.36.108
[*] NS ns-cloud-c3.googledomains.com 2001:4860:4802:36::6c
[*] NS ns-cloud-c4.googledomains.com 216.239.38.108
[*] NS ns-cloud-c4.googledomains.com 2001:4860:4802:38::6c
[*] MX aspmx.l.google.com 173.194.206.27
[*] MX alt1.aspmx.l.google.com 64.233.186.27
```

DNS Lookups (Cont.)

- A partir daí, um atacante pode começar a cavar mais fundo escaneando os hosts identificados.
- Uma vez que o agressor sabe quais hosts estão vivos no site alvo, ele ou ela então precisa determinar que tipo de serviços os hosts estão executando.
- Para fazer isso, o agressor pode usar a ferramenta Nmap confiável e comprovada.
- Antes de discutir esta ferramenta e outras em profundidade, precisamos observar os tipos de verificações e enumerações que você deve executar e o porquê.
- Você pode usar outras ferramentas DNS básicas, como por exemplo, nslookup , **host** e **comandos Linux dig** , para executar a resolução do nome e obter informações adicionais sobre um domínio.
- O exemplo mostra como a ferramenta dig é usada para mostrar os detalhes de resolução de DNS do h4cker.org.
- As linhas realçadas mostram os endereços IP associados à h4cker.org.

```
--[omar@websploit]--[~]
|--- $dig h4cker.org
; <<>> DiG 9.16.6-Debian <<>> h4cker.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 6517
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;h4cker.org.                IN      A
;; ANSWER SECTION:
h4cker.org.                172     IN      A      185.199.110.153
h4cker.org.                172     IN      A      185.199.111.153
h4cker.org.                172     IN      A      185.199.108.153
h4cker.org.                172     IN      A      185.199.109.153
;; Query time: 72 msec
;; SERVER: 208.67.222.222#53(208.67.222.222)
;; WHEN: Fri Apr 30 20:45:42 EDT 2021
;; MSG SIZE rcvd: 103

--[omar@websploit]--[~]
|--- $
```

Buscas DNS (Cont.)

- Da mesma forma, você pode usar o **comando dig** < domain > **mx** para obter os servidores de e-mail usados por h4cker.org (registro de mail exchanger [MX]), conforme mostrado no exemplo.

```
--[omar@websploit]--[~]
|--- $dig h4cker.org mx

; <<>> DiG 9.16.6-Debian <<>> h4cker.org mx
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 62903
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;h4cker.org.                IN      MX

;; ANSWER SECTION:
h4cker.org.  77      IN      MX      1  aspmx.l.google.com.
h4cker.org.  77      IN      MX      5  alt1.aspmx.l.google.com.
h4cker.org.  77      IN      MX      5  alt2.aspmx.l.google.com.
h4cker.org.  77      IN      MX     10  alt3.aspmx.l.google.com.
h4cker.org.  77      IN      MX     10  alt4.aspmx.l.google.com.

;; Query time: 48 msec
;; SERVER: 208.67.222.222#53(208.67.222.222)
;; WHEN: Fri Apr 30 20:47:01 EDT 2021
;; MSG SIZE  rcvd: 157
```

Identificação de contatos técnicos e administrativos

- Você pode identificar facilmente contatos técnicos e administrativos do domínio usando a ferramenta Whois.
- Muitas organizações mantêm seus detalhes de registro privados e, em vez disso, usam os contatos da organização de registro de domínio.
- Examinemos os contatos técnicos e administrativos do h4cker.org mostrado no exemplo.
 - Omar Santos é proprietário do domínio h4cker.org; no entanto, os detalhes técnicos e administrativos são privados.
 - Somente o e-mail de contato e o número de telefone do Google (o registrador de domínio) são exibidos.

```
--[omar@websploit]--[~]  
|--- $ whois h4cker.org  
Domain Name: H4CKER.ORG  
Registry Domain ID: D40220000006011258-LROR  
Registrar WHOIS Server: whois.google.com  
Registrar URL: https://domains.google.com  
Updated Date: 2018-07-03T03:48:35Z  
Creation Date: 2018-05-04T03:43:52Z  
Registry Expiry Date: 2028-05-04T03:43:52Z  
Registrar Registration Expiration Date:  
Registrar: Google LLC  
Registrar IANA ID: 895  
Registrar Abuse Contact Email: registrar-abuse@google.com  
Registrar Abuse Contact Phone: +1.8772376466  
Reseller:  
Domain Status: ok https://icann.org/epp#ok  
Registrant Organization: Contact Privacy Inc. Customer 1242605855  
Registrant State/Province: ON  
Registrant Country: CA  
Name Server: NS-CLOUD-C1.GOOGLEDOMAINS.COM  
Name Server: NS-CLOUD-C2.GOOGLEDOMAINS.COM  
Name Server: NS-CLOUD-C4.GOOGLEDOMAINS.COM  
Name Server: NS-CLOUD-C3.GOOGLEDOMAINS.COM  
DNSSEC: signedDelegation  
URL of the ICANN Whois Inaccuracy Complaint Form https://www.icann.org/wicf/
```

Identificação de contatos técnicos e administrativos (Cont.)

- Agora, vamos olhar para os detalhes Whois de tesla.com, mostrados no exemplo (saída omitida para brevidade).
- As linhas realçadas mostram os contatos técnicos e administrativos do domínio (que também são os do registrador de domínio [MarkMonitor]).

```
--[omar@websploit]--[~]
|--- $whois tesla.com
Domain Name: TESLA.COM
Registry Domain ID: 187902_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2083895740
Domain Status: serverUpdateProhibited
https://icann.org/epp#serverUpdateProhibited
Name Server: A1-12.AKAM.NET
Name Server: A10-67.AKAM.NET
Name Server: A12-64.AKAM.NET
Name Server: A28-65.AKAM.NET
Name Server: A7-66.AKAM.NET
Name Server: A9-67.AKAM.NET
Name Server: EDNS69.ULTRADNS.BIZ
Name Server: EDNS69.ULTRADNS.COM
Name Server: EDNS69.ULTRADNS.NET
Name Server: EDNS69.ULTRADNS.ORG
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form:
https://www.icann.org/wicf/
<output omitted for brevity>
```


Identificação de contatos técnicos e administrativos (Cont.)

- Este exemplo mostra os contatos de email técnicos e administrativos para o domínio cisco.com.
- Os contatos técnicos e administrativos estão apontando para a equipe do InfoSec na Cisco (infosec@cisco.com) em vez de para o registrante.

```
|--[omar@websploit]--[~]  
|--- $whois cisco.com | grep '@cisco.com'  
Registrant Email: infosec@cisco.com  
Admin Email: infosec@cisco.com  
Tech Email: infosec@cisco.com
```

Cloud vs. Aplicativos auto-hospedados e subdomínios relacionados

- Uma empresa pode ser dona de um domínio e subdomínio relacionado, mas seus aplicativos podem estar hospedados na nuvem.
- Por exemplo, a Netflix (no momento da escrita) possui o domínio `netflix.com`, que resolve para endereços IPv4 3.230.129.93, 52.3.144.142, e 54.237.226.164 (conforme demonstrado com o comando `host` **Linux**). (saída omitida para brevidade).
- No entanto, os endereços 3.230.129.93, 52.3.144.142, e 54.237.226.164 são de propriedade da Amazon Web Services (AWS), que hospeda Netflix.com
- Neste exemplo, o **comando whois** é usado para recuperar o nome da organização (OrgName) do proprietário para cada um dos endereços IP 3.230.129.93, 52.3.144.142, e 54.237.226.164.

```
--[omar@websploit]--[~]  
--- $host netflix.com  
netflix.com has address 3.230.129.93  
netflix.com has address 52.3.144.142  
netflix.com has address 54.237.226.164
```

```
--[omar@websploit]--[~]  
--- $whois 3.230.129.93 | grep OrgName  
OrgName:      Amazon Technologies Inc.  
OrgName:      Amazon Data Services NoVa  
--[omar@websploit]--[~]  
--- $whois 52.3.144.142 | grep OrgName  
OrgName:      Amazon Technologies Inc.  
--[omar@websploit]--[~]  
--- $whois 54.237.226.164 | grep OrgName  
OrgName:      Amazon Technologies Inc.  
OrgName:      Amazon.com, Inc.
```

Mídia Social

- Os atacantes podem facilmente reunir informações valiosas sobre as vítimas, raspando sites de mídia social como Twitter, LinkedIn, Facebook e Instagram.
- Muitas vezes, os agressores usam outras informações, como contatos-chave (partes interessadas na empresa) e suas responsabilidades de trabalho.
- Os atacantes podem usar todas essas informações para executar diferentes tipos de ataques de engenharia social (incluindo spear phishing e whaling).
- Os atacantes geralmente aproveitam as listagens de empregos em sites como Indeed, LinkedIn, CareerBuilder e sites de empresas individuais para obter informações sobre as tecnologias que essas empresas usam.
- Os atacantes também criaram posts de emprego para atrair pessoas para se candidatarem a essas posições.
- Em seguida, eles entrevistam suas vítimas para tentar fazê-las falar sobre o que fazem no trabalho e as tecnologias usadas por seu empregador.

Falhas criptográficas

- Durante a fase de reconhecimento, os atacantes muitas vezes podem inspecionar certificados Secure Sockets Layer (SSL) para obter informações sobre a organização, possíveis falhas criptográficas e implementações fracas.
- Você pode encontrar muito dentro de certificados digitais: o número de série do certificado, o nome comum do assunto, o identificador uniforme de recursos (URI) do servidor ao qual ele foi atribuído, o nome da organização, informações do OCSP (Online Certificate Status Protocol), a lista de revogação de certificados URI e utilizar para enumerar subdomínios.
- O objetivo da transparência de certificados é que qualquer organização ou indivíduo possa verificar de forma transparente a emissão de um certificado digital.
- A transparência de certificados permite que as autoridades certificadoras (CAs) forneçam detalhes sobre todos os certificados que foram emitidos para um determinado domínio e organização.
- Os atacantes também podem usar essas informações para revelar quais outros subdomínios e sistemas uma organização pode possuir.

Reputação da empresa e postura de segurança

- Brechas de segurança podem ter um impacto direto na reputação de uma empresa.
- Os agressores podem aproveitar informações de brechas de segurança passadas que uma organização pode ter experimentado.
- Eles podem, por exemplo, aproveitar os seguintes dados ao tentar reunir informações sobre suas vítimas:
 - Dumps de senhas
 - Metadados de arquivo
 - Análise/enumeração do mecanismo de pesquisa estratégico
 - Arquivamento/cache de sites
 - Repositórios de código-fonte público

Reputação da empresa e postura de segurança (cont.)

Vazamentos de senhas

- Os agressores podem aproveitar os vazamentos de senhas de violações anteriores.
- Há várias maneiras de que um agressor possa ter acesso a tais vazamentos de senhas, como usando Pastebin, sites da dark web e até mesmo GitHub em alguns casos.
- Um exemplo de uma ferramenta que permite encontrar endereços de e-mail e senhas expostos em violações anteriores é o **h8mail**.
- Você pode instalar o h8mail usando o comando do **pip3** **install h8mail**, conforme mostrado no exemplo.
- Ele também mostra o uso da linha de comando do h8mail.

```
root@websploit# pip3 install h8mail
Collecting h8mail
  Downloading h8mail-2.5.5-py3-none-any.whl (33 kB)
Requirement already satisfied: requests in /usr/lib/python3/
dist-packages (from h8mail) (2.23.0)
Installing collected packages: h8mail
Successfully installed h8mail-2.5.5
root@websploit# h8mail -h
usage: h8mail [-h] [-t USER_TARGETS [USER_TARGETS ...]] [-u USER_URLS [USER_URLS ...]] [-q USER_QUERY] [--
loose] [-c CONFIG_FILE [CONFIG_FILE ...]] [-o OUTPUT_FILE] [-j OUTPUT_JSON] [-bc BC_PATH] [-sk] [-k
CLI_APIKEYS [CLI_APIKEYS ...]]
           [-lb LOCAL_BREACH_SRC [LOCAL_BREACH_SRC ...]] [-gz LOCAL_GZIP_SRC [LOCAL_GZIP_SRC ...]] [--sf]
[-ch [CHASE_LIMIT]] [--power-chase] [--hide] [--debug] [--gen-config]

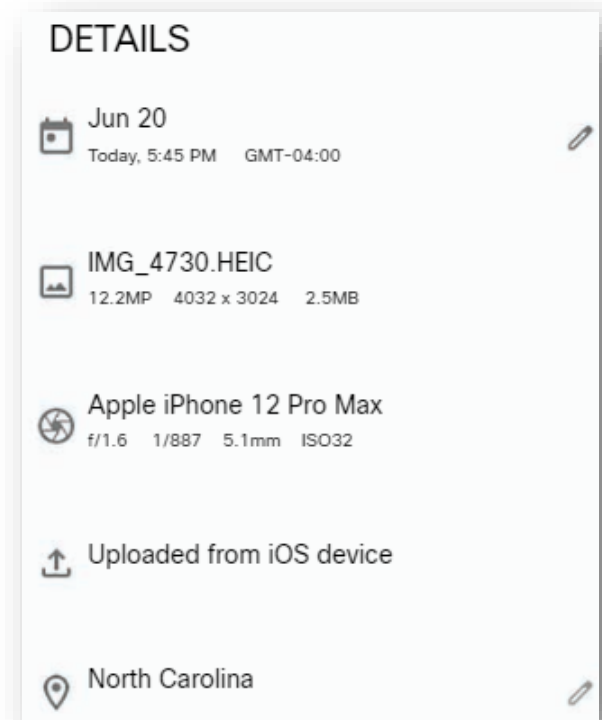
Email information and password lookup tool

options:
  -h, --help            show this help message and exit
  -t USER_TARGETS [USER_TARGETS ...], --targets USER_TARGETS [USER_TARGETS ...]
                        Either string inputs or files. Supports email pattern matching from input or file,
                        filepath globbing and multiple arguments
  -u USER_URLS [USER_URLS ...], --url USER_URLS [USER_URLS ...]
                        Either string inputs or files. Supports URL pattern matching from input or file,
                        filepath globbing and multiple arguments. Parse URLs page for emails. Requires http:// or https:// in URL.
  -q USER_QUERY, --custom-query USER_QUERY
                        Perform a custom query. Supports username, password, ip, hash, domain. Performs an
                        implicit "loose" search when searching locally
```

Reputação da empresa e postura de segurança (cont.)

Metadados de arquivo

- Você pode obter muitas informações dos metadados em arquivos como imagens, documentos do Microsoft Word, arquivos do Excel, arquivos do PowerPoint e muito mais.
- Por exemplo, Exif é uma especificação que define os formatos para imagens, som e tags suplementares usados por câmeras digitais, celulares, scanners e outros sistemas que processam arquivos de imagem e som.
- A figura mostra os dados Exif de uma imagem digital (imagem) capturada por um iPhone.



Reputação da empresa e Security Posture (cont.)

- Várias ferramentas podem mostrar detalhes do Exif.
- Uma das mais populares, ExifTool, é demonstrada neste exemplo (saída omitida para concisão).
- Ele mostra os detalhes dos metadados do Exif da mesma imagem cujos detalhes são mostrados na figura anterior.



```
[--[omar@websploit]--[~]
|--- $exiftool IMG_4730.jpg
ExifTool Version Number      : 12.06
File Name                    : IMG_4730.jpg
Directory                   : .
File Size                    : 2.4 MB
File Modification Date/Time  : 2021:06:20 21:33:36-04:00
File Access Date/Time       : 2021:06:20 21:33:36-04:00
File Inode Change Date/Time  : 2021:06:20 21:33:36-04:00
File Permissions             : rw-r--r--
File Type                    : JPEG
File Type Extension         : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Exif Byte Order              : Big-endian (Motorola, MM)
Make                         : Apple
Camera Model Name            : iPhone 12 Pro Max
Orientation                  : Horizontal (normal)
X Resolution                  : 72
Y Resolution                  : 72
Resolution Unit              : inches
Software                     : 14.6
Modify Date                  : 2021:06:20 17:45:44
Host Computer                : iPhone 12 Pro Max
Tile Width                   : 512
Tile Length                  : 512
```

Reputação da empresa e postura de segurança (cont.)

Análise/Enumeração estratégica de mecanismos de pesquisa

- A maioria de nós usa mecanismos de pesquisa como Wogle.net, Yandex, DuckDuckGo, Bing e Google para localizar informações.
- O Google pode traduzir documentos, executar pesquisas de notícias e fazer pesquisas de imagens, chamado *de Google hacking*.
- Ao usar técnicas de pesquisa básicas combinadas com operadores avançados, você e os atacantes podem usar o Google como uma ferramenta de pesquisa de vulnerabilidade poderosa.
- Veja a seguir alguns operadores avançados:
 - **Filetype:** Direciona o Google a pesquisar somente no texto de um tipo particular de arquivo (por exemplo, filetype:xls)
 - **Inurl:** Direciona o Google para pesquisar somente na URL especificada de um documento (por exemplo, inurl:texto de pesquisa)
 - **Link:** Direciona o Google para pesquisar em hiperlinks para um termo específico (por exemplo, link:www.domain.com)
 - **Intitle:** Direciona o Google a procurar um termo no título de um documento (por exemplo, intitle: "Índice de /etc")

Reputação da empresa e postura de Security (cont.)

- Usando esses operadores avançados em combinação com termos-chave, você e os atacantes podem fazer com que o Google descubra muitas informações confidenciais que não devem ser reveladas.
- Essas sequências de pesquisa são muitas vezes chamadas *de dorks do Google*.
- Para ver como o dorking do Google funciona, digite a seguinte frase no Google:
intext:JSESSIONID OU intext:PHPSESSION inurl:access.log ext:log
- Esta consulta procura em uma URL as IDs de sessão que podem ser usadas para fazer-se passar por usuários.
- Não é incomum esta pesquisa encontrar mais de 100 sites que armazenam IDs de sessão sensíveis em logs que estavam acessíveis publicamente.
- Se esses IDs não tiverem expirado, podem ser usados para obter acesso a recursos restritos.
- Você pode usar operadores avançados para procurar vários tipos de dados.
- Outro exemplo de uma cadeia de caracteres de pesquisa do Google (ou dork do Google) que pode revelar senhas de aplicativos da Web:

"public \$user =" | "public \$password =" | "public \$secret =" | "public \$db =" ext:txt | ext:log -git

Reputação da empresa e postura de Security (cont.)

- Para dar uma olhada em técnicas avançadas de hacking do Google, visite os repositórios do Google Hacking Database (GHDB).
- Algumas das seguintes categorias de pesquisa GHDB são:
 - Pontos de acesso
 - Arquivos que contêm nomes de usuário
 - Diretórios sensíveis
 - Detecção de servidor da Web
 - Arquivos vulneráveis
 - Servidores vulneráveis
 - Mensagem de erro
- GHDB é um esforço comunitário.
- Qualquer pessoa pode carregar um novo google dork para executar esses tipos de pesquisa.
- Assim que começar a jogar com os dorks em GHDB, você ficará surpreso com as coisas inacreditáveis encontradas através do hacking do Google.
- GHDB tornou o uso de dorks do Google muito fácil, e há outras opções também.

Reputação da empresa e postura de Security (cont.)

Arquivamento/cache de sites

- Várias organizações arquivam e fazem cache de dados de sites na Internet.
- Um dos repositórios mais populares é a "Máquina Wayback" do Internet Archive.
- A Máquina do Wayback permite que você volte no tempo na Internet.
- Por exemplo, a figura mostra como era o site da Cisco em 3 de novembro de 1999.



Reputação da empresa e postura de Security (cont.)

Repositórios de código-fonte público

- Um agressor pode obter informações extremamente valiosas de repositórios de código de origem pública, como GitHub e GitLab.
- A maioria dos aplicativos e produtos que consumimos hoje usam software de código aberto que está livremente disponível nesses repositórios públicos.
- Os agressores podem encontrar vulnerabilidades nesses pacotes de software e usá-los a seu favor.
- Da mesma forma, como testador de penetração, você pode obter informações valiosas desses repositórios públicos.
- Mesmo que você não encontre imediatamente vulnerabilidades de segurança no código, esses repositórios podem fornecer-lhe insights sobre a arquitetura e o código subjacente usado nos aplicativos e infraestrutura da organização.

Coleta de Inteligência de Fonte Aberta (OSINT)

- ***A coleta de inteligência de fonte aberta (OSINT) é um método de coleta de fontes de inteligência disponíveis publicamente para coletar e analisar informações sobre um alvo.***
- O OSINT é de "fonte aberta" porque a coleta de informações não exige nenhum tipo de método secreto.
- Geralmente, as informações podem ser encontradas na Internet.
- Quanto maior a presença on-line do alvo, mais informações estarão disponíveis.
- Esse tipo de coleta pode frequentemente começar com uma simples pesquisa no Google, que pode revelar uma quantidade significativa de informações sobre um alvo.
- Ele pelo menos fornecerá informações suficientes para saber para que direção seguir com seu processo de coleta de informações.
- Vamos cobrir duas ferramentas que podem ser usadas para a coleta OSINT: Recong-ng e Shodan.

Coleta de Inteligência de Fonte Aberta (OSINT) (cont.)

Recon-ng

- Este módulo abrange várias fontes e ferramentas individuais usadas para coleta de informações.
- Não seria ótimo se houvesse uma ferramenta que pudesse unir todas essas funções diferentes?
- É aqui que o Recon-ng entra.
- Esta ferramenta foi desenvolvida em Python com Metasploit **msfconsole** em mente.
- Se você já usou o console Metasploit antes, o Recon-ng deve ser familiar e fácil de entender.
- O Recon-ng é uma estrutura modular, que facilita o desenvolvimento e integração de novas funcionalidades.
- É altamente eficaz na enumeração de sites de rede social devido ao seu uso de APIs para reunir informações.
- Ela também inclui um recurso de relatório que permite exportar dados em diferentes formatos de relatório.
- Como você sempre precisará fornecer algum tipo de entrega em qualquer teste que fizer, o Recon-ng é especialmente valioso.
- O Recon-ng é incrivelmente poderoso porque usa as APIs de vários recursos OSINT para reunir informações.
- Seus módulos podem consultar sites como Facebook, Indeed, Flickr, Instagram, Shodan, LinkedIn e YouTube.

Coleta de Inteligência de Fonte Aberta (OSINT) (cont.)

As etapas a seguir são um exemplo da execução do Recon-ng em Kali Linux.

- **Etapa 1: Iniciar Recon-ng**
 - Para começar a usar o Recon-ng, você apenas executa o **recon-ng** a partir de uma nova janela de terminal.
- **Etapa 2. Exibir comandos disponíveis**
 - Para ter uma ideia de quais comandos estão disponíveis na ferramenta linha de comandos Recon-ng, é possível simplesmente digitar **help** e pressionar Enter.
- **Etapa 3. Procure módulos disponíveis.**
 - Antes de começar a reunir as informações usando a ferramenta Recon-ng, você precisa entender quais módulos estão disponíveis.
 - O Recon-ng é fornecido com um "mercado", onde é possível procurar módulos disponíveis para serem instalados.
 - Você pode usar o **comando 'marketplace search'** para procurar todos os módulos disponíveis em Recon-ng.
- **Etapa 4. Atualizar o marketplace.**
 - Você pode atualizar os dados sobre os módulos disponíveis usando o comando de atualização do marketplace.
- **Etapa 5. Pesquisar no marketplace.**
 - É possível fazer uma busca rápida para localizar diferentes subdomínios de um domínio.
 - Você pode executar uma pesquisa de palavra-chave em qualquer módulo usando o comando de pesquisa do marketplace **< keyword >**.

Coleta de Inteligência de Fonte Aberta (OSINT) (cont.)

As etapas a seguir são um exemplo da execução do Recon-ng em Kali Linux.

- **Etapla 6: Instalar um módulo**

- Diversos resultados corresponderam à palavra-chave.
- No entanto, há uma em que você está interessado.
- Você pode instalar o módulo usando o comando marketplace de instalação.

- **Etapla 7. Mostrar módulos instalados**

- Você pode usar o **comando de busca de módulos** para mostrar todos os módulos que foram instalados no Recon-ng.

- **Etapla 8. Carregar um módulo.**

- Para carregar o módulo que você gostaria de usar, use o comando modules load.
- O prompt é alterado para incluir o nome do módulo carregado.
- Após o módulo ser carregado, você pode exibir as opções do módulo usando o **comando info** .

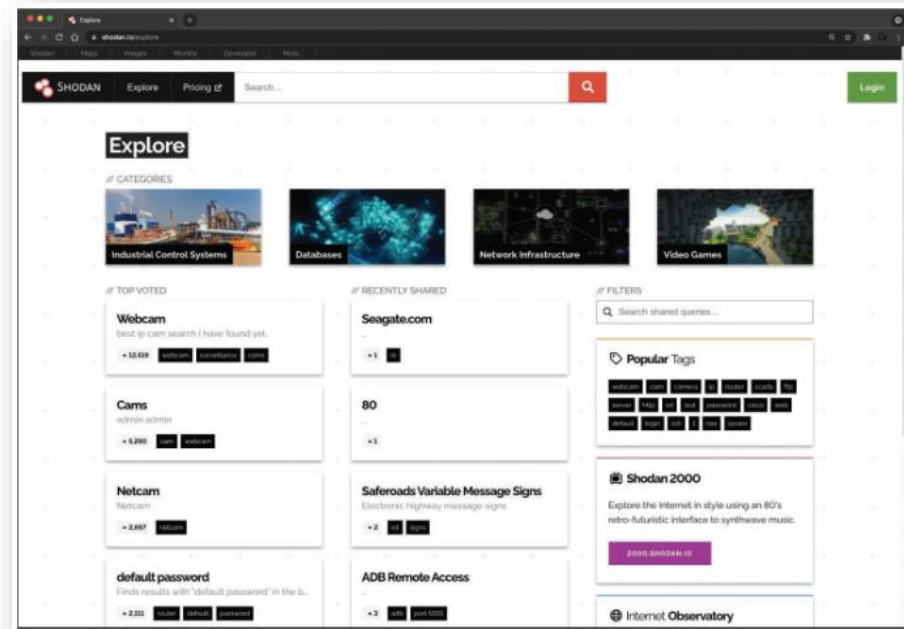
- **Etapla 9. Altere a origem.**

- É possível alterar a origem (o domínio a ser usado para localizar seus subdomínios) usando o comando options set SOURCE.
- Depois que o domínio de origem estiver definido, você pode digitar **rodar** para executar a consulta.
- As linhas realçadas mostram os subdomínios encontrados utilizando-se um módulo específico.

Coleta de Inteligência de Código Aberto (OSINT) (cont.)

Shodan

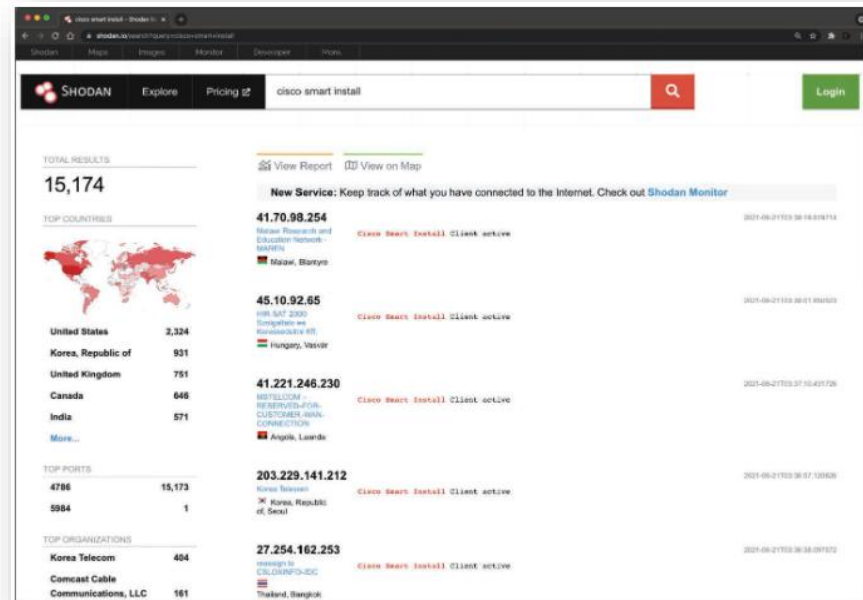
- É uma organização que verifica a Internet 24 horas por dia, 365 dias por ano.
- Os resultados dessas varreduras são armazenados em um banco de dados que pode ser consultado em shodan.io ou usando uma API.
- Pode ser usado para consultar hosts vulneráveis, dispositivos de IoT e muitos outros sistemas que não devem ser expostos ou conectados à Internet pública.
- A figura mostra diferentes categorias de sistemas encontrados por verificações de Shodan, incluindo sistemas de controle industrial (ICS), bancos de dados, dispositivos de infraestrutura de rede e videogames.



Coleta de Inteligência de Código Aberto (OSINT) (cont.)

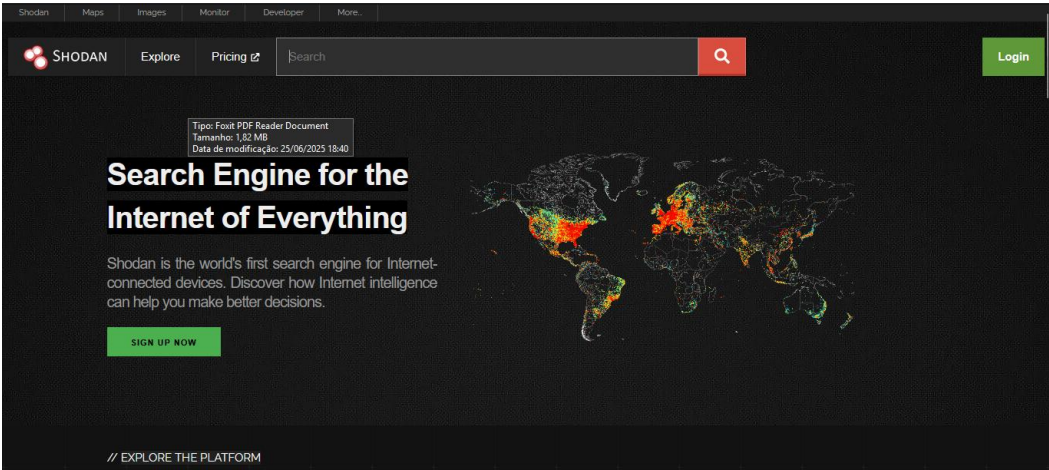
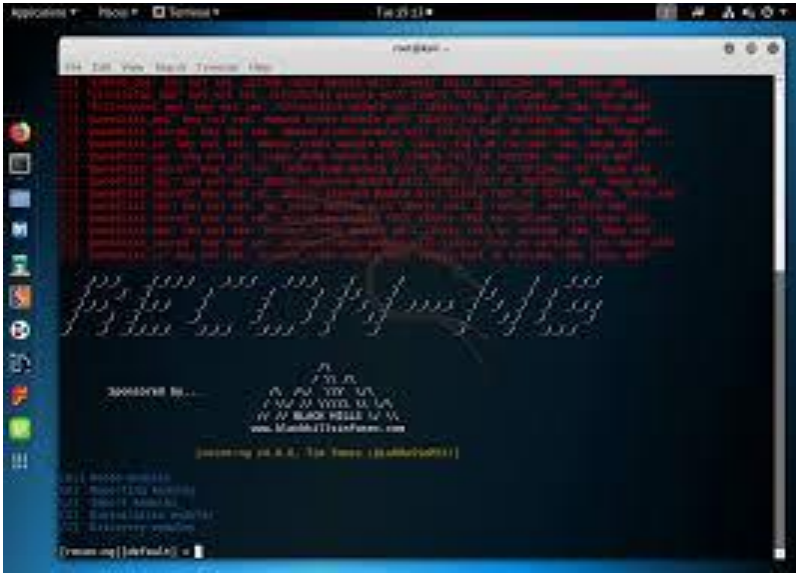
Shodan

- A figura mostra uma consulta realizada para encontrar dispositivos de infra-estrutura de rede que estejam executando um protocolo quebrado chamado Cisco Smart Install.
- Os atacantes aproveitaram este protocolo por anos para comprometer diferentes infra-estruturas.
- A Cisco removeu este protocolo de seus sistemas há muitos anos.
- No entanto, muitas pessoas ainda o estão usando em dispositivos conectados à Internet pública.



Executando reconhecimento passivo

Recon-ng & Shodan



3.2 Executando Reconhecimento Ativo

Visão geral

- Com cada etapa da fase de coleta de informações, a meta é reunir informações adicionais sobre o destino. O processo de coleta dessas informações é chamado enumeração.
- A enumeração externa de hosts é geralmente uma das primeiras coisas que você faz em um teste de penetração.
- Determinar os hosts voltados para a Internet de uma rede-alvo pode ajudá-lo a identificar os sistemas mais expostos.
- Depois de identificar esses sistemas, você precisa identificar quais serviços estão acessíveis.
- Para determinar se uma rede está executando algum serviço, você pode executar uma verificação de porta para enumerar os serviços que estão em execução nos hosts expostos.

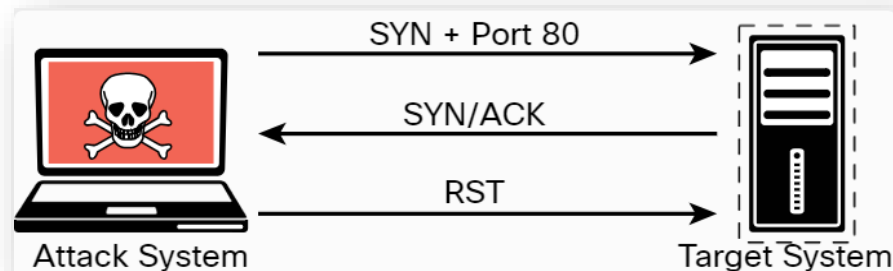
Visão geral (Cont.)

- Uma **verificação** de porta é uma verificação ativa na qual a ferramenta de varredura envia vários tipos de sondas para o endereço IP de destino e examina as respostas para determinar se o serviço está escutando.
- Por exemplo, com uma verificação Nmap SYN, a ferramenta envia um pacote TCP SYN para a porta TCP que está sondando.
- Esse processo também é referido como varredura semiaberta porque não abre uma conexão TCP completa.
- Se a resposta for SYN/ACK, isso indicaria que a porta está em estado de escuta.
- Se a resposta para o pacote SYN for um RST (redefinição), isso indicaria que a porta está fechada ou não está em estado de escuta.
- Se a sonda SYN não receber resposta, o Nmap a marcará como filtrada porque não pode determinar se a porta está aberta ou fechada.
- A tabela define as respostas de verificação SYN ao usar Nmap.

Relatório de Status da Porta Nmap	Resposta do Alvo	Análise Nmap
Aberto	TCP SYN-ACK	O serviço está escutando na porta.
Fechado	TCP RST	O serviço não está escutando na porta.
Filtrado	Nenhuma resposta do destino ou destino ICMP inacessível	A porta está protegida por um firewall.

Visão geral (Cont.)

- A figura ilustra como uma SYN scan funciona.



- O exemplo mostra como executar uma verificação de SYN TCP usando Nmap ao especificar a opção **sS** em um host com o endereço IP 192.168.88.251.
- Como você pode ver, esse sistema tem várias portas abertas.
- Em algumas situações, você deverá usar as diversas opções do Nmap em suas verificações para obter os resultados que está procurando.

```
--[root@websploit]--[~]
|---- #nmap -sS 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org )
Nmap scan report for 192.168.88.251
Host is up (0.00011s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
8888/tcp  open  sun-answerbook
9000/tcp  open  cslistener
9090/tcp  open  zeus-admin
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
```

Tipos de verificação Nmap

- Algumas das opções de varredura Nmap mais comuns usadas para cenários específicos, incluindo:
 - Verificação de conexão TCP (**-sT**)
 - Verificação de UDP (**-sU**)
 - Verificação FIN TCP (**-sF**)
 - Varredura de descoberta de host (**-sn**)
 - Opções de Temporização (**-T 0-5**)

Verificação de conexão TCP (**-sT**)

- Uma verificação de conexão TCP faz uso do mecanismo de rede do sistema operacional subjacente para estabelecer uma conexão TCP completa com o dispositivo de destino sendo digitalizado.
- Por criar uma conexão completa, ele cria mais tráfego (e portanto leva mais tempo para ser executado).
- Esse é o tipo de verificação padrão usado se nenhum tipo de verificação for especificado com o **comando nmap** .
- No entanto, ele deve normalmente ser usado apenas quando um SYN scan não é uma opção, como por exemplo, quando um usuário que está executando o **comando nmap** não tem privilégios de pacote bruto no sistema operacional porque muitos dos tipos de verificação Nmap dependem da gravação de pacotes brutos.

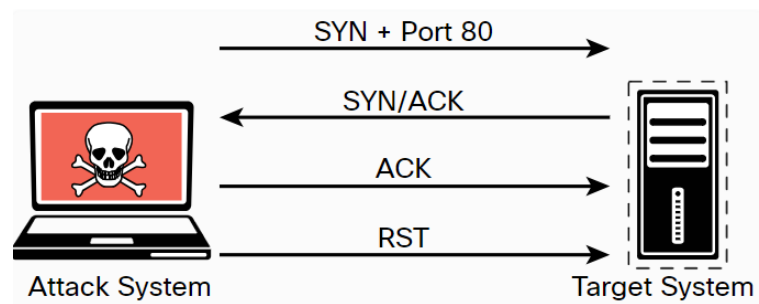
Tipos de verificação Nmap (cont.)

Verificação de conexão TCP (-sT) (cont.)

- A tabela define as respostas de verificação da conexão TCP.

Relatório de Status da Porta Nmap	Resposta do Destino	Análise Nmap
Abrir	TCP SYN-ACK	O serviço está escutando na porta.
Fechado	TCP RST	O serviço não está escutando na porta.
Filtrado	Nenhuma resposta do alvo	A porta está protegida por firewall.

- A figura ilustra como funciona uma verificação de conexão TCP.



Tipos de verificação Nmap (cont.)

Verificação de conexão TCP (-sT) (cont.)

- A saída na figura mostra os resultados de uma verificação de conexão Nmap TCP.
- Uma verificação de conexão TCP completa requer o scanner para enviar um pacote adicional por verificação, o que aumenta a quantidade de ruído na rede e pode disparar alarmes que uma verificação semi-aberta não acionaria.
- As ferramentas de segurança e o sistema alvo subjacente são mais propensos a registrar uma conexão TCP completa, e os sistemas de detecção de intrusão (IDSs) são igualmente mais propensos a disparar alarmes em várias conexões TCP do mesmo host.

```
[--[root@websploit]--[~]
|--- #nmap -sT 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 12:48 EDT
Nmap scan report for 192.168.88.251
Host is up (0.00024s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
8888/tcp  open  sun-answerbook
9000/tcp  open  cslistener
9090/tcp  open  zeus-admin
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
```

Tipos de verificação Nmap (cont.)

Verificação de UDP (-sU)

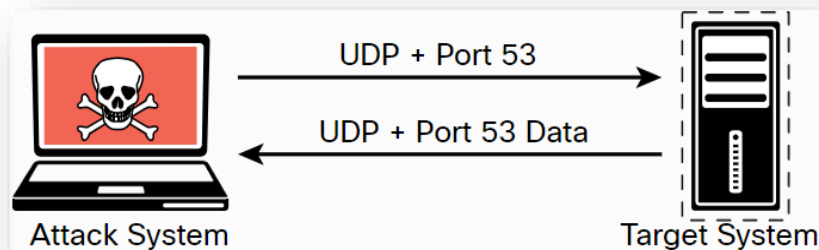
- Você pode encontrar algumas instâncias nas quais precisa verificar as portas UDP – por exemplo, se estiver tentando enumerar um servidor DNS, SNMP ou DHCP.
- Todos esses serviços usam o UDP para comunicação entre cliente e servidor.
- Para escanear as portas UDP, o Nmap envia um pacote UDP para todas as portas especificadas na configuração da linha de comando.
- Ele aguarda uma resposta do alvo.
- Se receber uma mensagem ICMP de porta inacessível de um alvo, essa porta será marcada como fechada.
- Se não receber resposta da porta UDP de destino, Nmap marcará a porta como aberta/filtrada.
- A tabela mostra as respostas de varredura do UDP.

Relatório de Status da Porta Nmap	Resposta do Alvo	Análise Nmap
Aberto	Dados retornados da porta	O serviço está escutando na porta.
Fechado	Mensagem de erro do ICMP recebida	O serviço não está escutando na porta.
Aberto/filtrado	Nenhuma resposta do ICMP do alvo	A porta está protegida por firewall ou com tempo de espera esgotado.

Tipos de verificação Nmap (cont.)

Verificação UDP (-sU) (cont.)

- A figura ilustra como uma verificação UDP funciona.



- A saída no exemplo mostra os resultados de uma verificação Nmap UDP na porta 53 do destino 192.168.88.251.
- Como você pode ver, os resultados indicam que esta porta está aberta.

```
--[root@websploit]--[~]
--- # nmap -sU -p 53 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 13:12 EDT
Nmap scan report for 192.168.88.251
Host is up (0.00057s latency).
PORT      STATE SERVICE
53/udp    open  domain
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

Tipos de scan Nmap (cont.)

Scan FIN TCP (-sF)

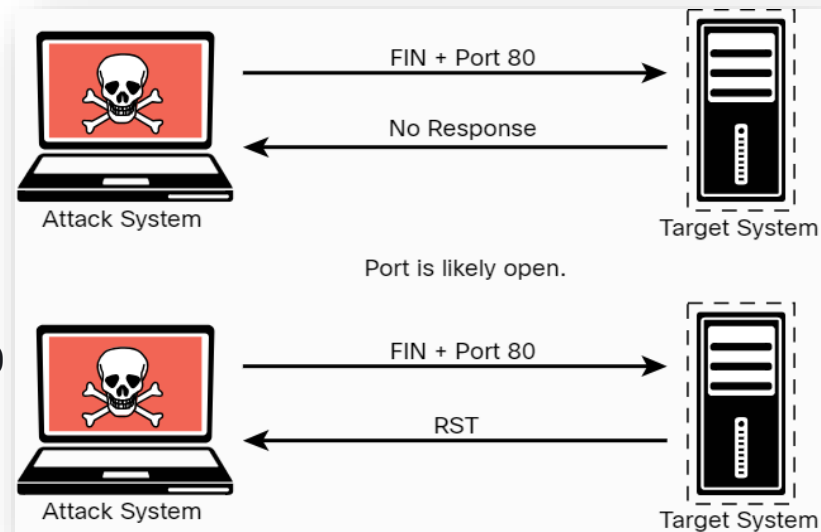
- Há momentos em que uma verificação SYN pode ser detectada por um filtro de rede ou firewall.
- Nesse caso, você precisa empregar um tipo diferente de pacote em uma verificação de porta.
- Com o escaneamento FIN TCP, um pacote FIN é enviado para uma porta de destino.
- Se a porta estiver fechada, o sistema de destino enviará de volta um pacote RST.
- Se nada for recebido da porta de destino, você poderá considerar a porta aberta porque o comportamento normal seria ignorar o pacote FIN.
- A Tabela mostra as Respostas de Escaneamento FIN TCP

Status Relatado da Porta Nmap	Resposta do Alvo	Análise Nmap
Aberto	Erro de ICMP de destino inalcançável recebido	A porta fechada deve responder com RST.
Fechado	Pacote RST recebido	A porta fechada deve responder com RST.
Aberta/filtrada	Nenhuma resposta recebida	A porta aberta deve descartar FIN.

Tipos de scan Nmap (cont.)

Varredura TCP FIN (-sF) (cont.)

- A figura ilustra como uma varredura TCP FIN funciona.
- A saída de exemplo mostra os resultados de uma verificação FIN do TCP Nmap, especificando a porta 80 no destino.
- A resposta do destino indica que a porta está aberta/filtrada.



```
--[root@websploit]--[~]
--- # nmap -sF -p 80 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 13:15 EDT
Nmap scan report for 192.168.88.251
Host is up (0.00045s latency).
PORT      STATE      SERVICE
80/tcp    open|filtered http
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds
--[root@websploit]--[~]
--- #
```


Tipos de varredura Nmap (cont.)

Varredura de descoberta de hosts (-sn)

- Uma verificação de descoberta de host é um dos tipos mais comuns de verificação usados para enumerar hosts em uma rede, pois pode usar diferentes tipos de mensagens do ICMP para determinar se um host está online e respondendo em uma rede.
- O exemplo mostra uma verificação de ping da sub-rede 192.168.88.0/24.
- Esta é uma verificação de descoberta de host muito básica que pode ser realizada para determinar quais dispositivos em uma rede estão ativos.
- Tal verificação para a descoberta do host de toda uma sub-rede às vezes é referida como uma varredura de ping.

```
--[root@websploit]--[~]
|---- #nmap -sn 192.168.88.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 14:32 EDT
Nmap scan report for 192.168.88.1
Host is up (0.00045s latency).
MAC Address: E0:55:3D:E9:61:74 (Cisco Meraki)
Nmap scan report for 192.168.88.12
Host is up (0.00094s latency).
MAC Address: 0E:64:AF:27:9C:44 (Unknown)
Nmap scan report for 192.168.88.14
Host is up (0.0092s latency).
MAC Address: 00:B8:B3:FD:BF:C2 (Cisco Systems)
Nmap scan report for 192.168.88.24
Host is up (0.0033s latency).
MAC Address: 00:E1:6D:E5:43:C2 (Cisco Systems)
Nmap scan report for 192.168.88.32
Host is up (0.00046s latency).
MAC Address: BE:38:F5:2D:6C:C0 (Unknown)
Nmap scan report for 192.168.88.231
Host is up (0.00061s latency).
MAC Address: FE:82:8C:A3:D2:3C (Unknown)
Nmap scan report for 192.168.88.251
Host is up (0.00040s latency).
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap scan report for 192.168.88.71
Host is up.
Nmap scan report for 192.168.88.225
Host is up.
Nmap done: 256 IP addresses (11 hosts up) scanned in 2.45 seconds
--[root@websploit]--[~]
|--- #
```

Tipos de varredura Nmap (Cont.)

Opções de temporização (-T 0-5)

- O scanner Nmap fornece seis modelos de temporização que podem ser especificados com a opção -T e o número do modelo (0 a 5) ou nome.
- Os modelos de temporização Nmap permitem determinar o quão agressiva uma verificação será, ao mesmo tempo em que deixando o Nmap escolher os valores exatos de tempo.
- Estas são as opções de tempo:
 - **-T0** (Paranoico) : Muito lento, usado para evasão de IDS
 - **-T1** (Sorrateiro): Bastante lento, usado para evasão de IDS
 - **-T2** (Educado) : Diminui para consumir menos largura de banda, é executado cerca de 10 vezes mais lento que o padrão
 - **-T3** (Normal) : Padrão, um modelo de tempo dinâmico baseado na receptividade de alvo
 - **-T4** (Agressivo) : assume uma rede rápida e confiável e pode sobrecarregar os alvos
 - **-T5** (Insano) : muito agressivo; provavelmente sobrecarregará os alvos ou perderá portas abertas

Tipos de Enumeração

- Esta seção aborda técnicas de enumeração que devem ser realizadas na fase de coleta de informações de um teste de penetração.
- Você aprenderá como e quando essas técnicas de enumeração devem ser usadas.
- Esta seção também inclui exemplos de execução desses tipos de enumeração usando Nmap, bem como um mergulho profundo na criação de pacotes com Scapy.
 - Enumeração de host
 - Enumeração de usuários
 - Enumeração de grupos
 - Enumeração de Compartilhamento de Rede
 - Exemplos adicionais de enumeração de SMB
 - Enumeração de páginas da Web/Enumeração de aplicativos da Web
 - Enumeração de serviços
 - Explorando enumeração através da criação de pacotes

Tipos de Enumeração (Cont.)

Enumeração do Host

- A enumeração de hosts é uma das primeiras tarefas que você precisa realizar na fase de coleta de informações de um teste de penetração.
- **A enumeração** do Host é realizada internamente e externamente.
- Quando executado externamente, você normalmente deseja limitar os endereços IP que está fazendo a varredura para apenas os que fazem parte do escopo do teste.
- Isso reduz a chance de digitalizar inadvertidamente um endereço IP que você não está autorizado a testar.
- Ao realizar uma enumeração de host interna, você geralmente verifica a sub-rede ou sub-redes completas de endereços IP que estão sendo usados pelo destino.
- A enumeração do host é normalmente executada usando uma ferramenta como **Nmap** ou **Masscan**; no entanto, os scanners de vulnerabilidade também executam essa tarefa como parte de seus testes automatizados.

Tipos de Enumeração (Cont.)

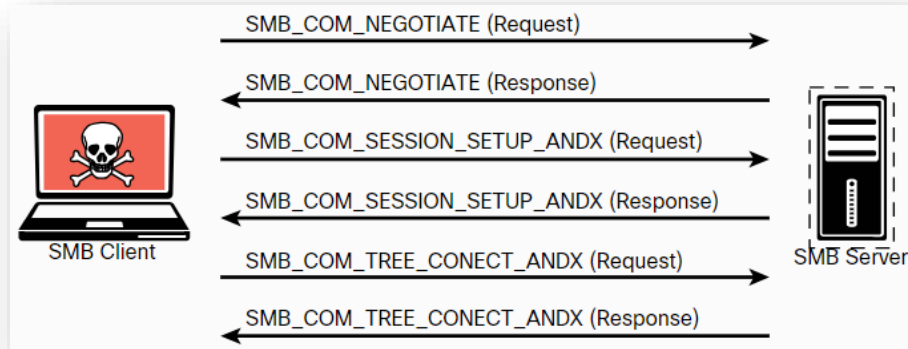
Enumeração de usuário

- Reunir uma lista válida de usuários é a primeira etapa para quebrar um conjunto de credenciais.
- Quando tiver o nome de usuário, você poderá iniciar ataques de força bruta para obter a senha da conta.
- Você executa **enumeração** de usuários quando tiver acesso à rede interna.
- Em uma rede do Windows, você pode fazer isso manipulando o protocolo SMB, que usa a porta TCP 445.

Tipos de Enumeração (Cont.)

Enumeração de Usuário

- A figura ilustra como uma implementação típica de SMB funciona.
- As informações contidas nas respostas a estas mensagens permitem que você revele informações sobre o servidor:
- **SMB_COM_NEGOTIATE:** Permite que o cliente informe ao servidor quais protocolos, sinalizadores e opções ele gostaria de usar. A resposta do servidor é também essa mensagem. Essa resposta é transmitida ao cliente sobre quais protocolos, sinalizadores e opções ele prefere. A resposta do servidor também fornece informações adicionais, como por exemplo, o horário e fuso horário que o servidor está usando. Essas são informações necessárias para muitas tarefas de teste de penetração.
- **SMB_COM_SESSION_SETUP_ANDX:** Depois que o cliente e o servidor tiverem negociado os protocolos, sinalizadores e opções que usarão para comunicação, o processo de autenticação começará. A autenticação é a função principal dessa mensagem. As informações enviadas nesta mensagem incluem o nome de usuário, a senha e o domínio do cliente.



Tipos de Enumeração (Cont.)

Enumeração do usuário (Cont.)

- O exemplo mostra os resultados do script Nmap **smb-enum-users** executado contra o alvo 192.168.88.251.
- Como você pode ver, os resultados indicam que o script foi capaz de enumerar os usuários que estão configurados neste alvo Windows.
- A linha realçada revela o usuário que foi enumerado pelo Nmap (derek).

```
|--[root@websploit]--[~]
|--- #nmap --script smb-enum-users.nse 192.168.88.251
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-22 11:14 EDT
Nmap scan report for 192.168.88.251
Host is up (0.012s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
8888/tcp  open  sun-answerbook
9000/tcp  open  cslistener
9090/tcp  open  zeus-admin
Host script results:
| smb-enum-users:
|   VULNHOST-1\derek (RID: 1000)
|   Full name:
|   Description:
|_  Flags:          Normal user account
Nmap done: 1 IP address (1 host up) scanned in 0.81 seconds
```

Tipos de Enumeração (Cont.)

Enumeração de grupos

- Para um pentest, **a enumeração** de grupos é útil na determinação dos papéis de autorização que estão sendo usados no ambiente de destino.
- O script Nmap NSE para enumeração de grupos de SMB é **smb-enum-groups**.
- Este script tenta obter uma lista de grupos de uma máquina remota do Windows.
- Você também pode revelar a lista de usuários que são membros desses grupos. A sintaxe do comando é a seguinte:
nmap --script smb-enum-groups.nse -p445<host>

- O exemplo mostra uma saída de exemplo desse comando executado no servidor Windows em 192.168.56.3
- Esse exemplo usa credenciais conhecidas para reunir informações.
- A saída realçada mostra os grupos enumerados e os usuários no host de destino.

```
|--[root@websploit]--[~]
|--- # nmap --script smb-enum-groups.nse --script-args smbusername=vagrant,smbpass=vagrant 192.168.56.3
Starting Nmap 7.91 ( https://nmap.org )
Nmap scan report for 192.168.56.3
Host is up (0.0062s latency).
Not shown: 979 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3306/tcp   open  mysql
3389/tcp   open  ms-wbt-server
MAC Address: 08:00:27:1B:A4:60 (Oracle VirtualBox virtual NIC)
Host script results:
| smb-enum-groups:
|   Builtin\Administrators (RID: 544): Administrator, vagrant, sshd_server
|   Builtin\Users (RID: 545): vagrant, sshd, sshd_server, leia_organa,
|   luke_skywalker, han_solo, artoo_detoo, c_three_pio, ben_kenobi, darth_
|   vader, anakin_skywalker, jarjar_binks, lando_calrissian, boba_fett,
|   jabba_hutt, greedo, chewbacca, kylo_ren
|   Builtin\Guests (RID: 546): Guest, ben_kenobi
|   Builtin\Power Users (RID: 547): boba_fett
|   Builtin\Print Operators (RID: 550): jabba_hutt
```


Tipos de Enumeração (Cont.)

Enumeração de Compartilhamento de rede

- Identificar sistemas em uma rede que estejam compartilhando arquivos, pastas e impressoras é útil na construção da superfície de ataque de uma rede interna.
- O script Nmap **smb-enum-shares** NSE usa o Microsoft Remote Procedure Call (MSRPC) para **enumeração de compartilhamento de rede**.
- A sintaxe do script Nmap **smb-enum-shares.nse** é a seguinte:
nmap --script smb-enum-shares.nse -p 445<host>
- O exemplo demonstra a enumeração de compartilhamentos SMB (saída omitida para brevidade).

```
--[root@websploit]--[~]
|--- # nmap --script smb-enum-shares.nse -p 445 192.168.88.251
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-22 11:27 EDT
Nmap scan report for 192.168.88.251
Host is up (0.0011s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-enum-shares:
|   account_used: guest
|   \\192.168.88.251\IPC$:
|     Type: STYPE_IPC_HIDDEN
|     Comment: IPC Service (Samba 4.9.5-Debian)
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|     Current user access: READ/WRITE
|   \\192.168.88.251\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: <none>
|     Current user access: <none>
|   \\192.168.88.251\secret_folder:
```

Tipos de Enumeração (Cont.)

Enumeração de páginas da Web/Enumeração de aplicativos da Web

- Depois de identificar que um servidor da Web está em execução em um host de destino, a próxima etapa é dar uma olhada no aplicativo Web e começar a mapear a superfície de ataque executando **enumeração de páginas da Web, ou frequentemente referida como** enumeração de aplicativos da Web.
- A ferramenta Nmap possui um script NSE disponível para forçar os caminhos de diretório e arquivo de aplicativos da Web.
- Armado com uma lista de arquivos e diretórios conhecidos usados por aplicativos da Web comuns, ele sonda o servidor para cada um dos itens da lista.
- Com base na resposta do servidor, ele pode determinar se esses caminhos existem.
- A sintaxe do script http-enum NSE é a seguinte:
nmap -sV --script=http-enum <target>
- O exemplo exibe os resultados da execução deste script no host com o endereço IP 192.168.88.251.
- A saída realçada mostra a versão do servidor web sendo usado (Nginx 1.17.2) e vários diretórios/pastas enumerados .

```
--[root@webexploit]--[~]
|--- #nmap -sV --script=http-enum -p 80 192.168.88.251
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-22 11:53 EDT
Nmap scan report for 192.168.88.251
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx 1.17.2
| http-enum:
|   /admin/: Possible admin folder
|   /admin/index.html: Possible admin folder
|_  /s/: Potentially interesting folder
|_ http-server-header: nginx/1.17.2
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.54 seconds
--[root@webexploit]--[~]
|--- #
```

Tipos de Enumeração (Cont.)

Enumeração de página da Web/Enumeração de Aplicativos Web (cont.)

- **Nikto** é outra ferramenta de enumeração de servidor da Web.
- É um scanner de vulnerabilidade da Web de código aberto que existe há muitos anos.
- É muito útil para executar um script rápido para enumerar informações sobre um servidor Web e os aplicativos que ele está hospedando.
- Devido à velocidade com que Nikto trabalha para escanear um servidor Web, **é muito barulhento**.
- Fornece várias opções para escanear, incluindo a capacidade de autenticar em um aplicativo Web que requer um nome de usuário e senha.
- .

```
--[root@websploit]--[~]
|--- #nikto -h 192.168.88.251
- Nikto v2.1.6

-----
+ Target IP:          192.168.88.251
+ Target Hostname:    192.168.88.251
+ Target Port:        80
-----
+ Server:  nginx/1.17.2
+ The anti-clickjacking X-Frame-Options header is not present.
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to
the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the
user agent to render the content of the site in a different fashion
to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible
dirs)
+ OSVDB-3092: /admin/: This might be interesting...
+ /admin/index.html: Admin login page/section found.
+ /wp-admin/: Admin login page/section found.
+ /wp-login/: Admin login page/section found.
+ 7916 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:          2021-06-22 11:57:59 (GMT-4) (15 seconds)
-----
+ 1 host(s) tested
--[root@websploit]--[~]
|--- #
```

Tipos de Enumeração (Cont.)

Enumeração de Serviços

- **A enumeração** de serviços é o processo de identificação dos serviços executados em um sistema remoto e é o foco principal do que o Nmap faz como um scanner de portas.
- Quando você estiver conectado a um sistema que está em um segmento de rede conectado diretamente, você poderá executar alguns scripts adicionais para enumerar mais.
- O script NMap **smb-enum-processes** NSE enumera serviços em um sistema do Windows e o faz usando credenciais de um usuário que tem acesso para ler o status dos serviços que estão em execução.
- Esta é uma ferramenta útil para consultar remotamente um sistema do Windows para determinar a lista exata de serviços em execução.
- A sintaxe do comando é a seguinte:

```
nmap --script smb-enum-processes.nse --script-args smbusername=<username>,  
smbpass=<password>-p445<host>
```

Inspeção e interceptação de pacotes

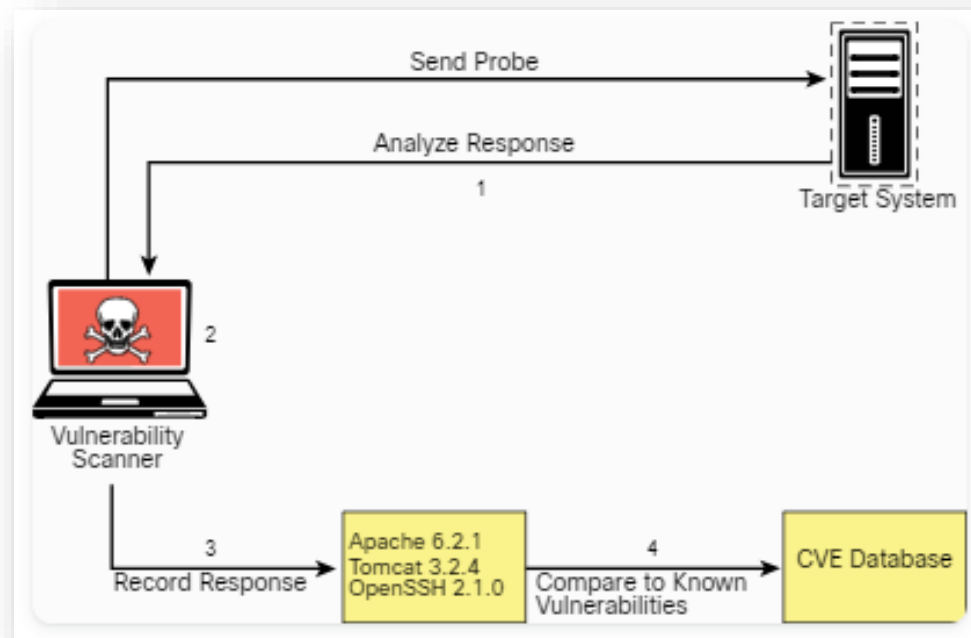
- Como testador de penetração, você pode usar ferramentas como Wireshark, tshark e tcpdump para coletar capturas de pacotes para inspeção de pacotes e interceptação.
- Para um testador de penetração, tais ferramentas podem ser convenientes para realizar reconhecimento passivo.
- Claro, este tipo de reconhecimento requer uma conexão física ou sem fio com o alvo.
- Se você está preocupado com ser detectado, provavelmente é mais vantajoso tentar uma conexão sem fio, pois ela não requer que você esteja dentro do prédio.
- Muitas vezes, a cobertura sem fio de uma empresa se estende além de suas paredes físicas.
- Isso dá a um testador de penetração a oportunidade de potencialmente coletar informações sobre o alvo e, possivelmente, obter acesso à rede para farejar o tráfego.

3.3 Entendendo a Arte de Realizar Verificações de Vulnerabilidade

Como funciona um scanner de vulnerabilidade automatizado típico

É assim que funciona um scanner de vulnerabilidade típico:

- Etapa 1. Na fase de descoberta, o scanner usa uma ferramenta como Nmap para realizar enumeração de hosts e portas.
- Etapa 2. Quando o scanner tem informações suficientes sobre a porta aberta para determinar qual software e versão estão sendo executados nessa porta, ele registra essas informações em um banco de dados para mais análises.
- Etapa 3. O scanner tenta determinar se o software que está escutando no sistema de destino é suscetível a alguma vulnerabilidade conhecida.
- Etapa 4. O scanner produz um relatório sobre o que suspeita que pode ser vulnerável.



Tipos de verificações de vulnerabilidade

- O tipo de verificação de vulnerabilidade a ser usado geralmente é impulsionado pela política de verificação criada na ferramenta automatizada de varredura de vulnerabilidades.
- Cada ferramenta possui diversas opções disponíveis para varredura.
- Muitas vezes, é possível optar por fazer uma verificação completa que irá operar todas as opções de varredura, embora talvez você não seja capaz de usar todas as opções (por exemplo, se estiver varrendo um ambiente de produção ou um dispositivo propenso a falhas quando ocorre a varredura).
- Em tais situações, você deve ter cuidado para selecionar apenas as opções de varredura que são menos propensas a causar problemas.
- Vejamos de perto os seguintes tipos típicos de varredura:
 - Verificações sem autenticação
 - Verificações autenticadas
 - Verificações de descoberta
 - Verificações completas
 - Verificações furtivas
 - Verificações de conformidade

Tipos de verificações de vulnerabilidade (cont.)

Verificações sem autenticação

- Por padrão, as ferramentas de escaneamento de vulnerabilidade não usam credenciais para escanear um alvo.
- Se você fornecer apenas o endereço IP do alvo e clicar em Digitalizar, a ferramenta começará a enumerar o host da perspectiva de um atacante remoto sem autenticação.
- Uma **verificação** não autenticada mostra apenas os serviços de rede expostos à rede.
- O scanner tenta enumerar as portas abertas no host de destino.
- Se o serviço não estiver escutando no segmento de rede ao qual o scanner está conectado, ou se estiver com firewall, o scanner relatará a porta como fechada e continuará.
- No entanto, isso não significa que não haja uma vulnerabilidade.
- Às vezes, é possível acessar portas que não são expostas à rede por meio do encaminhamento da porta SSH e outros truques.
- Ainda é importante executar uma verificação com credenciais (ou autenticada) quando possível.

Tipos de verificações de vulnerabilidade (cont.)

Verificações autenticadas

- Em alguns casos, é melhor executar uma verificação autenticada contra um alvo para obter uma imagem completa da superfície de ataque.
- Uma **verificação** autenticada exige que você forneça ao scanner um conjunto de credenciais que tenham acesso de nível root do sistema.
- O scanner inicia a sessão no alvo via SSH ou algum outro mecanismo.
- Em seguida, ele executa comandos como **netstat** para reunir informações de dentro do host.
- Muitos dos comandos que o scanner executa requerem acesso em nível de raiz para obter as informações corretas do sistema.

Compreendendo a Arte de Realizar Varreduras de Vulnerabilidades

Tipos de Varreduras de Vulnerabilidades (cont.)

Varreduras Autenticadas (cont.)

- O primeiro exemplo mostra o **comando netstat** executado por um usuário não privilegiado (omar); o segundo exemplo mostra o **comando netstat** executado por um usuário raiz.
- Você pode ver que a saída é diferente para as diferentes permissões de nível de usuário.
- Especificamente, observe que quando executado como o usuário omar, o nome PID/programa não está disponível, e quando executado como o usuário root, essa informação é exibida.

```
omar@vulnhost-1 ~ % netstat -tunap
(Not all processes could be identified, non-
owned process info will not be shown, you would have to be root to see it all.)
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp      0      0 0.0.0.0:9000            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:9001            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:9002            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:139             0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:8881            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:8882            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:8883            0.0.0.0:*               LISTEN
tcp      0      0 0.0.0.0:8884            0.0.0.0:*               LISTEN
<output omitted for brevity>
```

```
omar@vulnhost-1 ~ % sudo netstat -tunap
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp      0      0 0.0.0.0:9000            0.0.0.0:*               LISTEN      1076/docker-proxy
tcp      0      0 0.0.0.0:9001            0.0.0.0:*               LISTEN      762/docker-proxy
tcp      0      0 0.0.0.0:9002            0.0.0.0:*               LISTEN      1287/docker-proxy
tcp      0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      1095/docker-proxy
tcp      0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      247/smbd
tcp      0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      506/docker-proxy
tcp      0      0 0.0.0.0:8881            0.0.0.0:*               LISTEN      831/docker-proxy
tcp      0      0 0.0.0.0:8882            0.0.0.0:*               LISTEN      530/docker-proxy
tcp      0      0 0.0.0.0:8883            0.0.0.0:*               LISTEN      702/docker-proxy
tcp      0      0 0.0.0.0:8884            0.0.0.0:*               LISTEN      1133/docker-proxy
tcp      0      0 0.0.0.0:8885            0.0.0.0:*               LISTEN      989/docker-proxy
tcp      0      0 0.0.0.0:8886            0.0.0.0:*               LISTEN      604/docker-proxy
tcp      0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      161/sshd
tcp      0      0 0.0.0.0:8887            0.0.0.0:*               LISTEN      1163/docker-proxy
tcp      0      0 0.0.0.0:8888            0.0.0.0:*               LISTEN      494/docker-proxy
tcp      0      0 0.0.0.0:88              0.0.0.0:*               LISTEN      482/docker-proxy
tcp      0      0 0.0.0.0:8889            0.0.0.0:*               LISTEN      470/docker-proxy
tcp      0      0 0.0.0.0:125             0.0.0.0:*               LISTEN      338/master
tcp      0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      247/smbd
tcp      0      0 0.0.0.0:9090            0.0.0.0:*               LISTEN      819/docker-proxy
<output omitted for brevity>
```

Tipos de varreduras de vulnerabilidade (cont.)

Varreduras de descoberta

- Uma **varredura de descoberta** destina-se principalmente a identificar a superfície de ataque de um alvo.
- Uma verificação de porta é uma parte importante do que uma verificação de descoberta realiza.
- Um scanner pode usar uma ferramenta como Nmap para realizar o processo de verificação de portas.
- Em seguida, extrai os resultados da verificação de portas em seu banco de dados para usar essas informações para descobertas posteriores.
- Por exemplo, o resultado da verificação de portas pode voltar mostrando que as portas 80, 22 e 443 estão abertas e ouvindo.
- A partir daí, a ferramenta de digitalização sonda essas portas para identificar exatamente qual serviço está sendo executado em cada porta.
- Por exemplo, suponha que ele identifique que um servidor web Apache Tomcat 8.5.22 está sendo executado nas portas 80 e 443.
- Sabendo que um servidor da Web está em execução nas portas, o scanner pode executar tarefas de descoberta mais específicas para servidores e aplicativos web.
- Agora diga que, ao mesmo tempo, o scanner identifica que OpenSSH está ouvindo na porta 22.
- A partir daí, o scanner pode sondar o serviço SSH para identificar informações sobre sua configuração e capacidades, como algoritmos criptográficos preferidos e suportados.
- Esse tipo de informação é útil para identificar vulnerabilidades em fases posteriores de testes.

Tipos de Varreduras de Vulnerabilidade (cont.)

Varreduras completas

- Geralmente, uma verificação completa envolve a ativação de todas as opções de varredura na política de varredura.
- As opções variam de acordo com o scanner, mas a maioria dos scanners de vulnerabilidade tem suas categorias de opções definidas de forma semelhante.
- Por exemplo, eles são normalmente organizados por sistema operacional, fabricante de dispositivos, tipo de dispositivo, protocolo, conformidade e tipo de ataque, e o restante das opções pode se encaixar em uma categoria diversa.
- O exemplo mostra uma lista de amostra das categorias de plug-in do scanner de vulnerabilidade de Nessus (saída omitida para brevidade).
- Há muitos plug-ins disponíveis para o scanner executar.
- Com base nos nomes das categorias de plug-in, nunca haverá um único dispositivo ao qual todos esses plug-ins se apliquem.
- Por exemplo, plug-ins para um dispositivo macOS não seriam aplicáveis a um dispositivo Windows.
- Normalmente, é necessário personalizar a seleção de plug-in para refletir o ambiente que você está escaneando.

Family	Count
AIX Local Security Checks	11416
Amazon Linux Local Security Checks	1048
Backdoors	114
Brute force attack	26
CGI abuses	3841
CGI abuses : XS	666
CISCO	918
CentOS Local Security Checks	2585
DNS	172
Databases	577
Debian Local Security Checks	5532
Default Unix Accounts	168
Denial of Service	109
F5 Networks Local Security Checks	607
FTP	255

Tipos de varreduras de vulnerabilidade (cont.)

Verificações furtivas

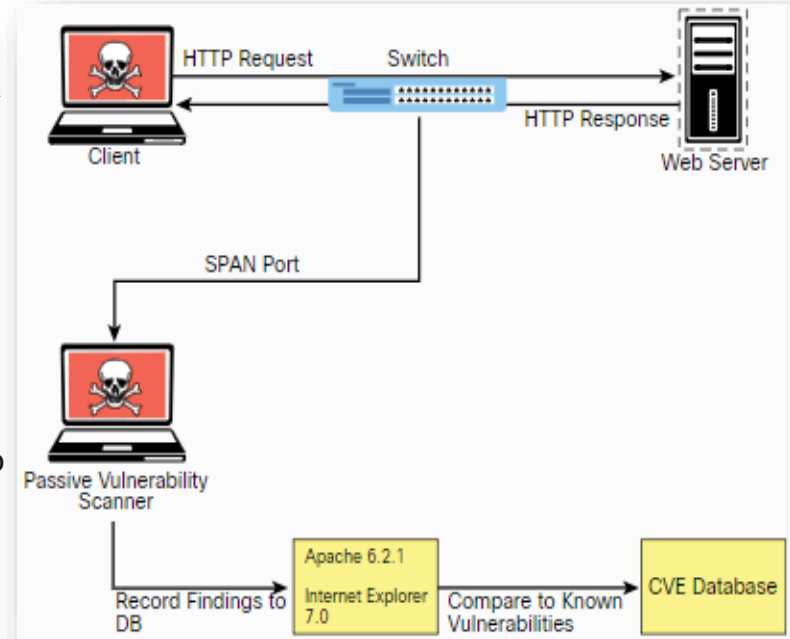
- Às vezes, há situações em que você deve verificar um ambiente que está em um estado de produção.
- Em tais situações, normalmente há um requisito para fazer uma verificação sem alertar a posição defensiva do ambiente; tal verificação é chamada de **furtiva**.
- Nesse caso, você vai querer implementar um scanner de vulnerabilidade de uma maneira que torne o alvo menos propenso a detectar a atividade.
- Scanners de vulnerabilidade são barulhentos; entretanto, há algumas opções que podem ser configuradas para torná-los mais silenciosos.
- Existem diferentes tipos de verificações Nmap e elas podem ser detectadas por IPSs (sistemas de prevenção de intrusão) ou firewalls de host.
- Um SYN scan é um tipo de verificação bastante furtivo para ser executado.
- Esse mesmo conceito aplica-se a scanners de vulnerabilidade porque todos usam algum tipo de scanner de portas para enumerar o alvo.
- Essas mesmas opções estão disponíveis na configuração do scanner de vulnerabilidade.
- Você também pode desativar quaisquer plug-ins/ataques que possam ser especialmente propensos a gerar tráfego barulhento, como qualquer um que realize ataques de negação de serviço, o que definitivamente despertaria algumas preocupações na rede de destino.

Compreendendo a arte de realizar scans de vulnerabilidade

Tipos de scans de vulnerabilidade (cont.)

Scans furtivos (cont.)

- Há também o conceito de um scanner de vulnerabilidade passivo que monitora e analisa o tráfego da rede.
- Com base no tráfego que ele enxerga, pode determinar em que a topologia da rede consiste e em quais serviços os hosts da rede estão escutando.
- A partir das informações detalhadas sobre o tráfego na camada de pacotes, ele pode determinar se algum desses serviços ou mesmo clientes têm vulnerabilidades.
- Por exemplo, se um cliente do Windows com uma versão ultrapassada do Internet Explorer estiver se conectando a um servidor da Web Apache que também está desatualizado, o scanner identificará as versões do cliente e do servidor do tráfego monitorado.
- Depois, ele pode comparar essas versões com seu banco de dados de vulnerabilidades conhecidas e relatar os achados com base apenas no monitoramento passivo realizado.
- A figura ilustra como esse tipo de scanner normalmente funciona.



Tipos de varreduras de vulnerabilidade (cont.)

Verificações de conformidade

- São testes de rede e de aplicativos (varreduras) normalmente orientados pelo mercado ou governança que o ambiente atende e pela conformidade regulatória.
- Um exemplo disso seria o ambiente de segurança da informação para uma entidade de saúde, que deve aderir aos requisitos estabelecidos pela HIPAA.
- É aqui que um scanner de vulnerabilidades entra em ação.
- É possível usar um scanner de vulnerabilidades para atender aos requisitos específicos exigidos por uma política.
- Os scanners de vulnerabilidade geralmente têm a capacidade de importar um arquivo de política de conformidade.
- Este arquivo de política normalmente pode associar-se a plugins/ataques específicos que o scanner é capaz de executar.
- Depois que a política é importada, o conjunto específico de verificações de conformidade pode ser executado em um sistema de destino.
- O desafio com os requisitos de conformidade é que há muitos tipos diferentes para diferentes setores e agências governamentais, e todos eles podem ser interpretados de várias maneiras.
- Algumas das verificações podem ser diretas.
- Se uma verificação de requisito estiver procurando um comando específico para ser executado e que a saída seja 1 em vez de 0, isso é muito simples para um scanner de vulnerabilidade determinar; no entanto, muitos requisitos deixam mais para ser interpretado.

Desafios a considerar ao executar uma verificação de vulnerabilidade

Algumas das coisas específicas que você deve considerar ao criar uma diretiva de varredura e efetuar varreduras:

- **Considerando a melhor hora para fazer uma varredura**

- O momento de quando executar uma varredura é geralmente mais preocupante quando você está varrendo uma rede de produção.
- Se você estiver varrendo um dispositivo em um ambiente de laboratório, normalmente não há muita preocupação porque um ambiente de laboratório não está sendo usado por aplicativos críticos.
- Há alguns motivos pelos quais a varredura em uma rede de produção deve ser feita com cuidado.
- Primeiro, o tráfego de rede que está sendo gerado por uma verificação de vulnerabilidade pode e causará muito ruído na rede.
- Também pode causar congestionamento significativo, especialmente quando seus escaneamentos estão atravessando vários saltos de rede.
- Outra consideração é o fato de que muitas das opções ou plug-ins que são realizadas em uma verificação de vulnerabilidade podem e derrubarão o dispositivo de destino, bem como a infraestrutura de rede.
- Por esse motivo, certifique-se de que, ao fazer a varredura em uma rede de produção, esteja escaneando em horários que terão o menor impacto possível nos usuários e servidores finais.
- Na maioria das vezes, realizar a varredura nas primeiras horas do dia, quando ninguém está usando uma rede para fins críticos, é a melhor opção.

Desafios a considerar ao executar uma verificação de vulnerabilidade (cont.)

- **Determinando quais protocolos estão em uso**

- Essa é uma das primeiras coisas que você precisa saber sobre uma rede ou dispositivo de destino antes de começar a executar verificações de vulnerabilidade.
- Se um dispositivo de destino estiver usando protocolos TCP e UDP para serviços em execução e você executar uma verificação de vulnerabilidade apenas nas portas TCP, então você perderá todas as vulnerabilidades que possam ser encontradas nos serviços do UDP.

- **Topologia de rede**

- A topologia da rede deve sempre ser considerada quando se trata de varredura de vulnerabilidade.
- É claro que a varredura através de uma conexão WAN nunca é recomendada porque afetaria significativamente qualquer um dos dispositivos ao longo do trajeto.
- A regra geral ao determinar onde na topologia da rede executar uma verificação de vulnerabilidade é que ela deve sempre ser executada o mais perto possível do alvo.
- Além do impacto na infra-estrutura da rede, outra preocupação é que qualquer dispositivo pelo qual você passa também pode afetar os resultados do scanner.
- Isso é uma preocupação principalmente ao atravessar um dispositivo de firewall; além disso, outros dispositivos de infra-estrutura de rede podem afetar também os resultados.

Desafios a considerar ao executar uma verificação de vulnerabilidade (cont.)

- **Limitações da largura de banda**

- Toda vez que você inunda uma rede com um monte de tráfego, isso vai causar um problema com a quantidade de largura de banda disponível.
- Como um profissional de teste de penetração, você precisa estar ciente de como você está afetando a largura de banda das redes ou sistemas que você está analisando.
- Especificamente, dependendo da quantidade de largura de banda que você tem entre o scanner e o alvo, talvez você precise ajustar as configurações do scanner para acomodar situações de largura de banda inferior.
- Se você estiver fazendo a varredura através de um link VPN ou WAN que tenha provavelmente uma largura de banda limitada, você vai querer ajustar as opções de varredura para que você não cause problemas de consumo de largura de banda.
- As configurações que precisam ser ajustadas são geralmente aquelas relacionadas a inundações e ataques de tipo de negação de serviço (DoS).

Desafios a considerar ao executar uma verificação de vulnerabilidade (cont.)

- **Limitação de Consulta**

- Para contornar o problema das limitações da largura de banda e da varredura de vulnerabilidades, reduzir o tráfego criado pelo scanner muitas vezes pode ajudar.
- Essa opção é frequentemente referida como **limitação** de consulta e pode normalmente ser feita modificando as opções da política de varredura.
- Uma maneira de fazer isso é reduzir o número de threads de ataque que estão sendo enviados para o alvo ao mesmo tempo.
- Não há uma regra geral específica para o número de threads.
- Depende realmente da robustez do alvo, e alguns alvos são mais frágeis do que outros.
- Outra maneira de realizar isso é reduzir o escopo de plug-ins/ataques que o scanner está verificando.
- Se você sabe que o dispositivo de destino é um servidor Linux, você pode desativar os ataques para outros sistemas operacionais, como o Windows.
- Embora os ataques não funcionem contra o servidor Linux, ele ainda precisa receber e responder ao tráfego.
- Esse tráfego adicional pode causar um gargalo no processamento e no consumo de tráfego em rede.
- Limitar o número de solicitações que o alvo precisaria responder reduziria o risco de causar

Desafios a considerar ao executar uma verificação de vulnerabilidade (cont.)

- **Sistemas frágeis/ativos não tradicionais**

- Ao usar um scanner de vulnerabilidade em sua rede interna, você deve levar em consideração os dispositivos da rede que podem não ser capazes de enfrentar o tráfego que é arremessado para eles por um scanner de vulnerabilidade.
- Para esses sistemas, pode ser necessário ajustar as opções de escaneamento para reduzir o risco de derrubar os dispositivos ou isentar completamente os dispositivos específicos de serem escaneados.
- Infelizmente, isentando os dispositivos específicos, você reduz a segurança geral do ambiente.
- As impressoras são frequentemente consideradas "sistemas frágeis".
- Historicamente, eles têm sido dispositivos que não foram capazes de suportar tentativas de varredura de vulnerabilidades.
- Com o aumento dos dispositivos de IoT, hoje existem muitos mais dispositivos que podem ser considerados frágeis e você precisa considerá-los ao planejar a varredura de vulnerabilidades.
- A maneira típica de lidar com dispositivos frágeis é isentá-los de uma verificação; no entanto, esses dispositivos podem representar um risco para o ambiente e precisam ser escaneados.
- Para resolver esse problema, você pode "limitar" a frequência de verificação, bem como as opções usadas na política de verificação para reduzir a probabilidade de causar falhas no dispositivo.

3.4 Compreendendo como analisar resultados de verificação de vulnerabilidade

Entendendo como analisar resultados de verificação de vulnerabilidade

Fontes para investigação adicional de vulnerabilidades

A tabela a seguir descreve algumas fontes úteis para uma investigação mais aprofundada das vulnerabilidades que podem ser localizadas durante os exames.

US-CERT (Equipe de Prontidão para Emergências de Computadores dos EUA)	Foi estabelecido para proteger a infra-estrutura de Internet dos Estados Unidos.A meta principal é trabalhar com agências do setor público e privado para aumentar a eficiência do compartilhamento de dados de vulnerabilidade.O trabalho feito pelo US-CERT foi destinado a melhorar a postura de cibersegurança do país.
A Divisão CERT da Universidade Carnegie Mellon	É um centro de cibersegurança cujos especialistas ajudam a coordenar divulgações de vulnerabilidade em toda a indústria.Ela pesquisa vulnerabilidades de segurança e contribui para vários esforços diferentes de cibersegurança na indústria.Ela também desenvolve e proporciona treinamento a muitas organizações para ajudá-las a melhorar suas práticas e programas de cibersegurança.
NIST (Instituto Nacional de Padrões e Tecnologia)	É uma agência do Departamento de Comércio dos EUA.Seu foco principal é promover a inovação e a competitividade industrial.O NIST é responsável pela criação da Estrutura de Cibersegurança do NIST.Essa estrutura inclui uma política de orientação de segurança da informação.Em geral, o quadro destaca as normas e as melhores práticas da indústria que podem ser usadas para melhorar a postura de cibersegurança das organizações.Qualquer pessoa que seja responsável por tomar decisões relacionadas à segurança cibernética em uma organização deve consultar essa estrutura para obter orientação sobre padrões e práticas recomendadas.

Fontes para Investigação Adicional de Vulnerabilidades (Cont.)

JPCERT (Equipe de Resposta de Emergência de Computador do Japão)	Semelhante ao US-CERT, o JPCERT é uma organização que trabalha com provedores de serviços, fornecedores de segurança e agências do setor privado e governamentais para fornecer capacidades de resposta a incidentes, aumentar a conscientização sobre cibersegurança, realizar pesquisas e análise de incidentes de segurança e trabalhar com outras equipes internacionais de CERT.É responsável pelas atividades da Equipe de Resposta a Incidentes de Segurança Computacional (CSIRT) na região Japonesa e do Pacífico Asiático.
CAPEC (Enumeração e Classificação de Padrões Comuns de Ataque)	É um esforço orientado pela comunidade para catalogar os padrões de ataque vistos em ambientes reais para que eles possam ser usados para identificar ameaças ativas de forma mais eficiente.É mantida pelo MITRE, agindo como um dicionário de ataques conhecidos que têm sido vistos no mundo real.
CVE (Vulnerabilidades e exposições comuns)	É um esforço que alcança comunidades internacionais de cibersegurança.Foi criado em 1999 com a ideia de consolidar ferramentas de cibersegurança e bancos de dados.Um ID CVE é composto pelas letras CVE seguidas pelo ano de publicação e quatro ou mais dígitos na parte do número de sequência do ID (por exemplo, CVE-YYYY-NNNN com quatro dígitos no número de sequência, CVE-YYYY-NNNNN com cinco dígitos no número de sequência, CVE-YYYY-NNNNNNN com sete dígitos no número de sequência e assim por diante).
CWE (Common Weakness Enumeration)	Está em um alto nível, sendo uma lista de fraquezas do software.Seu objetivo é criar uma linguagem comum para descrever as fraquezas de segurança do software que são as causas básicas de determinadas vulnerabilidades.CWE fornece uma linha de base comum para identificação de fraqueza para ajudar no processo de mitigação.

Fontes para Investigação Adicional de Vulnerabilidades (Cont.)

CVSS (Sistema de Pontuação de Vulnerabilidades Comum)

Cada vulnerabilidade representa um risco potencial que os atores de ameaça podem usar para comprometer seus sistemas e sua rede. Cada vulnerabilidade implica um nível de risco associado. Um dos padrões mais amplamente utilizados para calcular a gravidade de uma determinada vulnerabilidade é o CVSS, que possui três componentes: pontuações básicas, temporais e ambientais. Cada componente é apresentado como uma pontuação em uma escala de 0 a 10. No CVSS, uma vulnerabilidade é avaliada em três aspectos, com uma pontuação atribuída a cada um deles: o grupo base, o grupo temporal e o grupo ambiental. A pontuação para o grupo-base está entre 0 e 10, onde 0 é a menos grave e 10 é atribuído a vulnerabilidades altamente críticas. Além disso, a pontuação vem na forma de uma cadeia de caracteres vetorial que identifica cada um dos componentes usados para constituir a pontuação. A fórmula usada para obter a pontuação leva em consideração várias características da vulnerabilidade e como o atacante é capaz de aproveitar essas características. O CVSS define diversas características dos grupos base, temporal e ambiental. O grupo base define métricas de exploração que medem como a vulnerabilidade pode ser explorada, bem como métricas de impacto que medem o impacto na confidencialidade, integridade e disponibilidade. Além dessas duas métricas, uma métrica chamada Alteração de escopo (S) é usada para transmitir o impacto em outros sistemas que podem ser impactados pela vulnerabilidade, mas não contêm o código vulnerável.

Como lidar com uma vulnerabilidade

- Depois de identificar uma vulnerabilidade, você precisa verificá-la.
- A validação final é de exploit.
- Para determinar se uma vulnerabilidade é explorável, você precisa primeiro identificar um exploit para uma vulnerabilidade.
- Como regra geral, se uma vulnerabilidade tiver um módulo correspondente em Metasploit, quase sempre deve ser considerada alta gravidade.
- Para determinar a prioridade, você precisa responder algumas perguntas:
 - Qual é a gravidade da vulnerabilidade?
 - A quantos sistemas a vulnerabilidade se aplica?
 - Como a vulnerabilidade foi detectada?
 - A vulnerabilidade foi encontrada com um scanner automatizado ou manualmente?
 - Qual o valor do dispositivo no qual a vulnerabilidade foi encontrada?
 - Esse dispositivo é crítico para a sua empresa ou para a infraestrutura?
 - Qual é o vetor de ataque e isso se aplica ao seu ambiente?
 - Há uma solução alternativa ou mitigação possível disponível?

Como lidar com uma vulnerabilidade (cont.)

- Responder essas perguntas pode ajudá-lo a determinar a prioridade que você deve atribuir às vulnerabilidades encontradas.
- O protocolo padrão faria você começar com as vulnerabilidades de gravidade mais alta que têm a maior probabilidade de serem exploradas.
- Se a qualquer momento durante um teste de penetração, você descobrir que um sistema está sendo explorado ativamente, você deve reportá-lo imediatamente para o proprietário do sistema.
- Em seguida, você deve lidar com todas as vulnerabilidades que estiverem em sistemas críticos, independentemente do nível de gravidade.
- Você precisa proteger primeiro os sistemas críticos.
- Em seguida, você pode querer priorizar com base em quantos sistemas são afetados pela descoberta.
- Se um grande número de sistemas for afetado, isso aumentaria a prioridade porque muitas explorações sobre essa vulnerabilidade teriam um impacto maior no seu ambiente.
- Essas são diretrizes sugeridas, mas quando se trata de priorização de gerenciamento de vulnerabilidades e mitigação, ela realmente depende do ambiente específico.

CONCLUSÃO

Reflexão

- Depois que o contrato é assinado e o compromisso de teste de penetração está em andamento, é hora de aprender o máximo possível sobre a rede, aplicativos e sistemas do cliente.
- Reconhecimento passivo é uma boa maneira de começar.
- Que tipos de informações valiosas podem ser encontradas a partir do reconhecimento passivo?
- O reconhecimento ativo é mais intrusivo do que o reconhecimento passivo.
- Por causa disso, por que um testador precisa ter cuidado ao fazer reconhecimento ativo?
- Muitos scanners de vulnerabilidade são automatizados.
- Embora varredores de vulnerabilidade sejam geralmente precisos, é importante verificar manualmente alguns resultados.
- Ao analisar resultados de varredor de vulnerabilidade, por que é importante se familiarizar com CVE, CWE e CVSS?

Sgt JAIME

Instrutor da EsCom

Email: jaime.melo@eb.mil.br

Linkedin: <https://www.linkedin.com/in/jaime-gama-543643274/>

Escola de Comunicações

www.escom.eb.mil.br

